

ADMINISTRACIÓN DE SISTEMAS INFORMÁTICOS EN RED

PROYECTO FINAL

Desarrollo de un programa informático para gestionar, mediante interfaz gráfica, la base de datos de un taller mecánico implementando las medidas de seguridad correspondientes.



ÁLVARO CILLERUELO
SINOVAS

IES Julián Marías – 2021/2022

ÍNDICE

Índice	2
Resumen / Abstract	3
Resumen.....	3
Abstract.....	3
Conceptos.....	3
Introducción.....	4
Introducción	4
Procedimiento	4
Archivos del programa.....	4
Virtualización de Servidor	5
Base de Datos	7
Búsqueda y organización de la información.....	7
Implementación de la base de datos.....	8
Mejoras	9
Desarrollo del Programa.....	10
Estructura y diseño.....	10
Funcionalidad.....	12
Mejoras.....	22
Securización mediante certificado SSL/TLS	22
Protección de datos	25
Soporte vía Telegram.....	27
Otras mejoras interesantes no aplicadas	29
Fuentes Empleadas.....	31

RESUMEN / ABSTRACT

Resumen

El proyecto se basa en diseñar una base de datos que recoja todos los datos necesarios para el funcionamiento de un taller mecánico (coches, clientes...) y desarrollar la versión demostrativa de un programa flexible mediante el cual, a través de una interfaz gráfica intuitiva, insertar y consultar datos de esta base de datos. Este proyecto ofrecerá a los administradores de la empresa que lo implemente la posibilidad de gestionar los datos del taller mecánico sin necesidad de conocimientos en bases de datos ni desarrollo software. En la realización del proyecto se tienen en cuenta todas las medidas de seguridad y requerimientos legales. Finalmente, se establece una implementación con datos ficticios para comprobar su correcto funcionamiento.

Abstract

The project is based on designing a database that collects all the data necessary for the operation of a mechanical workshop (cars, customers...) and developing the demo version of a program whereby, through an intuitive graphical interface, insert and query data from this database. Therefore, this project will offer the administrators of the company the possibility of managing the data of the mechanical workshop without the need of knowledge in databases or software development. During this project, all security measures and legal requirements are taken into account. Finally, the project will be established with fictional data to check its correct functioning.

Conceptos

Ubuntu Server, Apache, MySQL, PHPMyAdmin, Visual Studio Code, Lucidchart, flexibilidad, intuitividad, sencillez, XAMPP, Weijan Chen, HTML5, CSS3, PHP, SSL/TLS, HTTPS, Ley de Protección de Datos, sTelegram chatbots, 2FA, optimización, automatización, PWAs, dinamismo, PDO.

INTRODUCCIÓN

Introducción

El proyecto nace a partir de la localización de un nicho en la industria automovilística descubierto gracias a la relación de mi familia con este sector. Una parte fundamental de la administración de un taller mecánico es la base de datos debido a la gran cantidad de información que procesan en su actividad corporativa (inventario, vehículos, clientes, etc.) y las soluciones con las que se encuentran son escasas (en comparación con la demanda), caras e incluyen gran cantidad de herramientas innecesarias que dificultan la tarea para aquellos administrativos sin grandes conocimientos en informática.

En busca de solucionar este problema, decido desarrollar esta solución flexible, ya que es sencilla para poder incorporar o eliminar utilidades; intuitiva, segura y de libre replicación. Esta versión básica del programa será tanto gratuita como *OpenSource*.

Procedimiento

Como organización del proyecto de cara a una mayor eficiencia divido el proceso en apartados para realizar ordenadamente las distintas fases de la producción del proyecto.

En primer lugar, virtualizo un servidor Linux y le instalo las herramientas necesarias para alojar la página web y la base de datos para simular un implantación real. Además, instalaré en local un servidor XAMPP para agilizar el desarrollo.

Con el entorno listo comienzo creando la base de datos cuyo proceso se divide en recopilar y organizar información sobre la actividad de los talleres mecánicos, traducir esta información en la base de datos e implementación de la misma y, finalmente, estudio de posibles mejoras para la misma.

Ya con la versión básica de la base de datos, procedo a crear la página web que interactuará con esta base de datos. Este proceso de programación lo divido en dos fases: estructura y diseño, fundamentada en HTML y CSS, y funcionalidad, fundamentada en PHP.

En último lugar, estudio las diversas mejoras aplicables al proyecto aplicando las más importantes para dar distintividad a este.

Archivos del programa

Como he comentado previamente, la versión del programa realizada en este documento será gratuita y OpenSource. El directorio web se encuentra en mi repositorio de GitHub en el siguiente enlace. Es posible que no aparezcan algunos archivos como el de la base de datos pero en ese caso sería fácilmente replicable siguiendo los pasos de este documento.

https://github.com/alvarocille/car_repair_database

VIRTUALIZACIÓN DE SERVIDOR

Para la versión de prueba del programa y la base de datos, virtualizo un servidor en nuestro equipo configurado en red con adaptador puente para así simular un servidor físico. Creo una máquina virtual empleando el entorno de Oracle VM VirtualBox y le instalo Ubuntu Server (sin interfaz gráfica) ya que es ligero y brinda las herramientas necesarias para la implantación del proyecto.

```
Ubuntu 22.04 LTS proyecto tty1
proyecto login: cilleruelo
Password:
Welcome to Ubuntu 22.04 LTS (GNU/Linux 5.15.0-30-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of mié 18 may 2022 21:01:58 UTC

System load:  0.171875      Processes:           135
Usage of /:   32.0% of 8.02GB Users logged in:        0
Memory usage: 5%           IPv4 address for enp0s3: 10.0.2.15
Swap usage:   0%

14 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

cilleruelo@proyecto:~$ _
```

Tras instalar el sistema operativo, aún es necesario implantar los servicios que permitan proveer la web. Para ello, instalo la pila LAMP (Linux, Apache, MySQL y PHP) de forma semiautomatizada con el siguiente script que desarrollé:

```
#!/bin/bash
apt update
apt-get install apache2
apt-get install mysql-server
apt-get install php libapache2-mod-php php-mysql
service apache2 restart
apt install phpmyadmin php-mbstring php-zip php-gd php-json php-curl
```

Compruebo que se han instalado los servicios correctamente (archivos creados, servicios corriendo y puertos abiertos) y el servidor está listo. Este se podría optimizar en gran

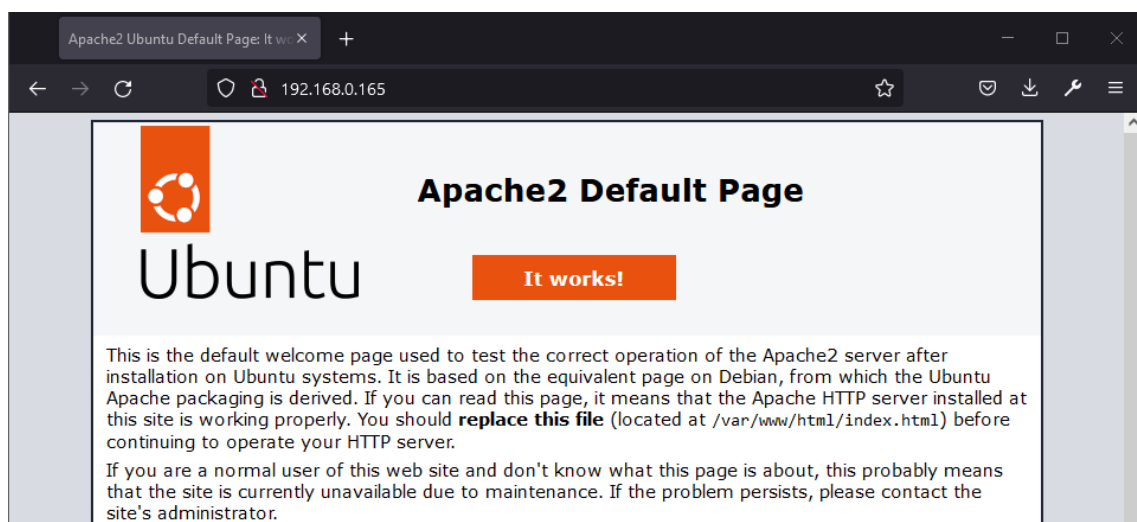
medida desactivando herramientas innecesarias como el esquema de rendimiento de MySQL pero no lo he considerado ya que se trata de una versión de prueba.

```
root@proyecto:/lamp# systemctl status apache2
root@proyecto:/lamp# systemctl status mysql
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; vendor preset: enabled)
   Active: active (running) since Wed 2022-03-02 12:00:00 CEST; 1min ago
     Main PID: 1234 (httpd)
   CGroup: /systemd/system/apache2.service
           └─ 1234 httpd -k start
● mysql.service - MySQL Community Server
   Loaded: loaded (/lib/systemd/system/mysql.service; vendor preset: enabled)
   Active: active (running) since Wed 2022-03-02 12:00:00 CEST; 1min ago
     Main PID: 1234 (mysqld)
   CGroup: /systemd/system/mysql.service
           └─ 1234 mysqld --defaults-file=/etc/mysql/my.cnf
```

Finalizo la instalación y configuración del servidor comprobando la conectividad de red.

```
cilleruelo@proyecto:~$ ip ad
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
    link/ether ff:ff:ff:ff:ff:ff brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.165/24 metric 100 brd 192.168.0.255 scope global dynamic enp0s3
        valid_lft 86369sec preferred_lft 86369sec
    inet6 fe80::a00:27ff:fe43:9665/64 scope link
        valid_lft forever preferred_lft forever
cilleruelo@proyecto:~$ ping google.es
PING google.es (142.250.201.67) 56(84) bytes of data.
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=1 ttl=118 time=13.5 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=2 ttl=118 time=12.9 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=3 ttl=118 time=12.4 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=4 ttl=118 time=40.2 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=5 ttl=118 time=62.1 ms
```

```
State      Recv-Q      Send-Q      Local Address:Port
LISTEN     0            70          127.0.0.1:33060
LISTEN     0            151         127.0.0.1:3306
LISTEN     0           4096        127.0.0.53%lo:53
LISTEN     0            128         0.0.0.0:22
LISTEN     0            511         *:80
LISTEN     0            128         [::]:22
```



No obstante, pese a contar con el servidor preparado para su funcionamiento lo complemento con un servidor XAMPP instalado en local permitiéndome realizar las tareas de desarrollo de forma más rápida y eficiente sin sufrir problemas de red.

BASE DE DATOS

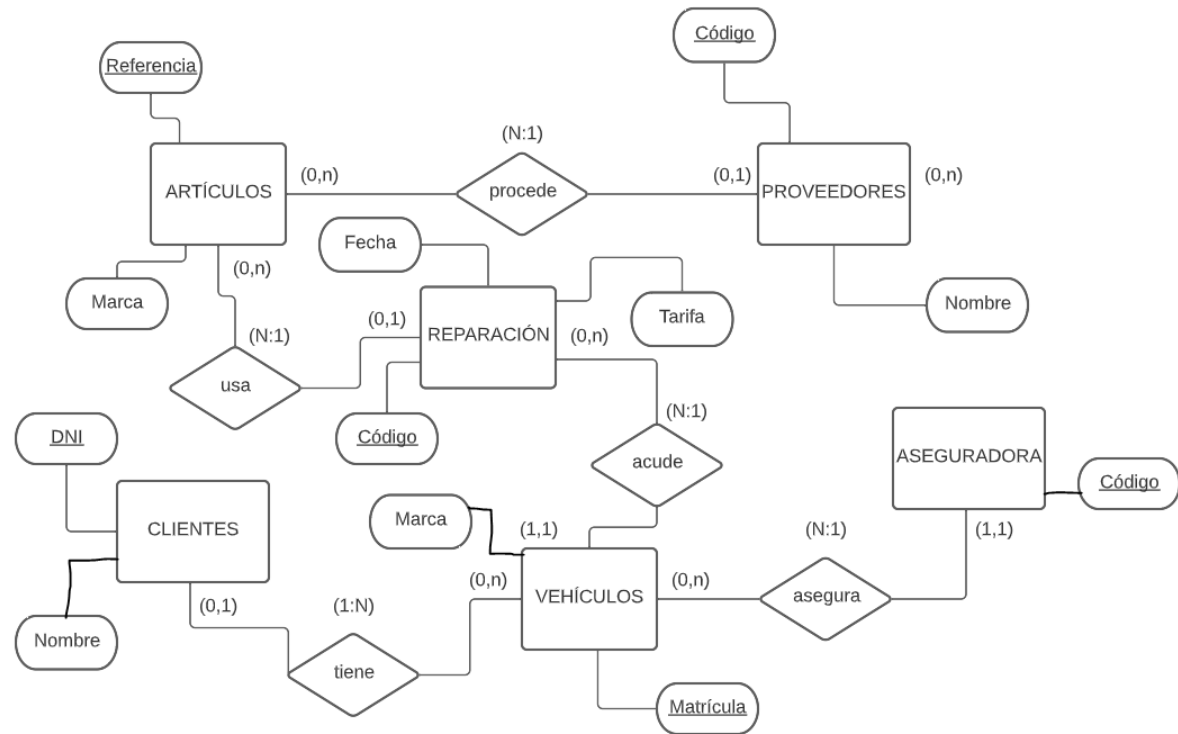
Búsqueda y organización de la información

Para desarrollar la base de datos empleada en el proyecto, necesitamos conocer qué tipo de información requieren almacenar los talleres mecánicos para el desarrollo de su actividad corporativa.

Con el objetivo anterior, me acerco a Talleres Cilleruelo – Peñafiel SL, en el municipio vallisoletano de Peñafiel, quienes se ofrecieron a colaborar en el proyecto contándonos sus necesidades de administración y almacenamiento de los datos. Tras una entrevista con el personal administrativo, obtenemos la información requerida.

<u>Artículos</u> Referencia* Descripción Marca Familia Proveedor, Precio tarifa Descuento Precio coste Impuesto Precio venta	<u>Clientes</u> Código* NIF Nombre Particular (bool) C Postal Población Provincia Teléfono 1 Teléfono 2 Correo Banco IBAN Vehículos, Otra info	<u>Aseguradoras</u> Nombre Código* NIF Dirección C Postal Población Teléfono Web Correo Otra info
<u>Proveedores</u> Código* NIF Nombre Dirección Población C Postal Teléfono 1 Teléfono 2 Web Correo Banco IBAN	<u>Reparación</u> Código* Fecha Vehículos, Artículos Tarifa	<u>Vehículos</u> Kilómetros Matrícula* Cliente, Marca Modelo Versión Última reparación, Última revisión (ITV) Próxima ITV Otra info Aseguradora, Datos seguro

Recopilación de información a mano para desarrollar una idea generalizada.

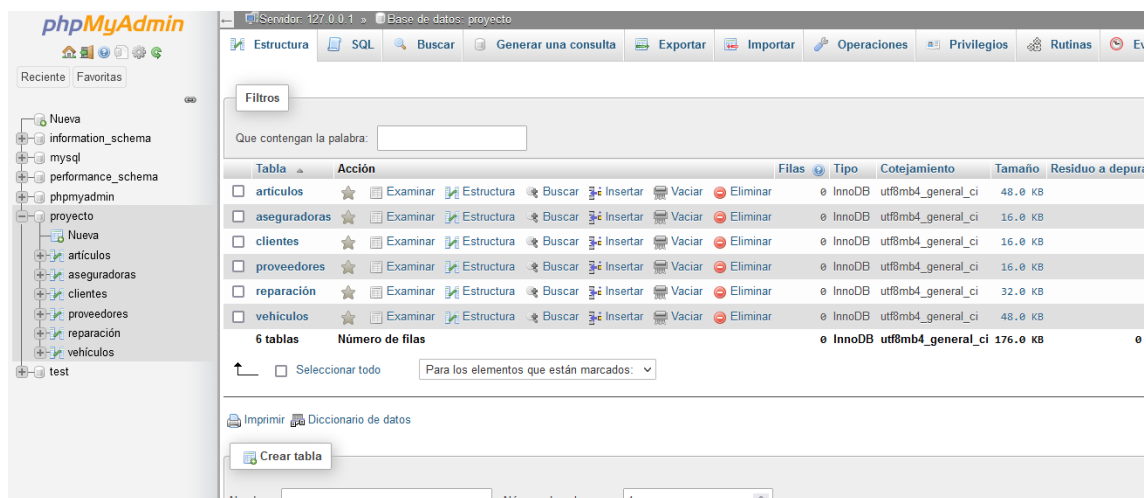


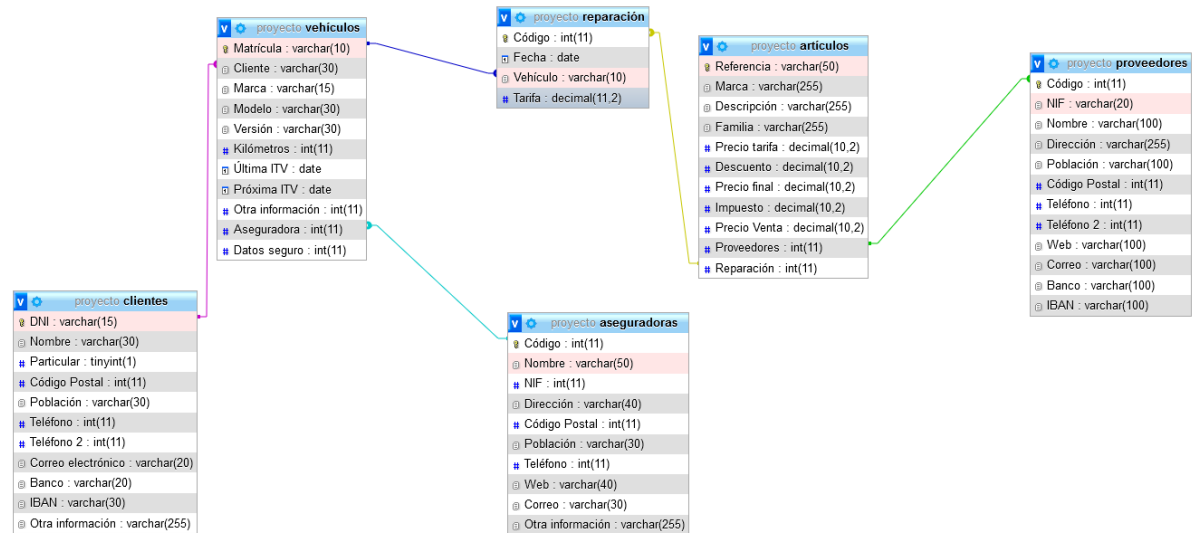
Esquema relacional creado con Lucidchart para organizar las tablas con sus relaciones y sus claves primarias.

Implementación de la base de datos

Una vez conocemos el diseño lógico de la base de datos, debemos llevarlo a la práctica. Para crear la estructura de la base de datos decidí emplear PHPMyAdmin ya que mediante interfaz gráfica permite realizar todas las operaciones además de mostrarte el código MySQL que emplea en cada acción permitiendo modificarlo o crearlo tú mismo y un panel para previsualizar el esquema en forma de tablas.

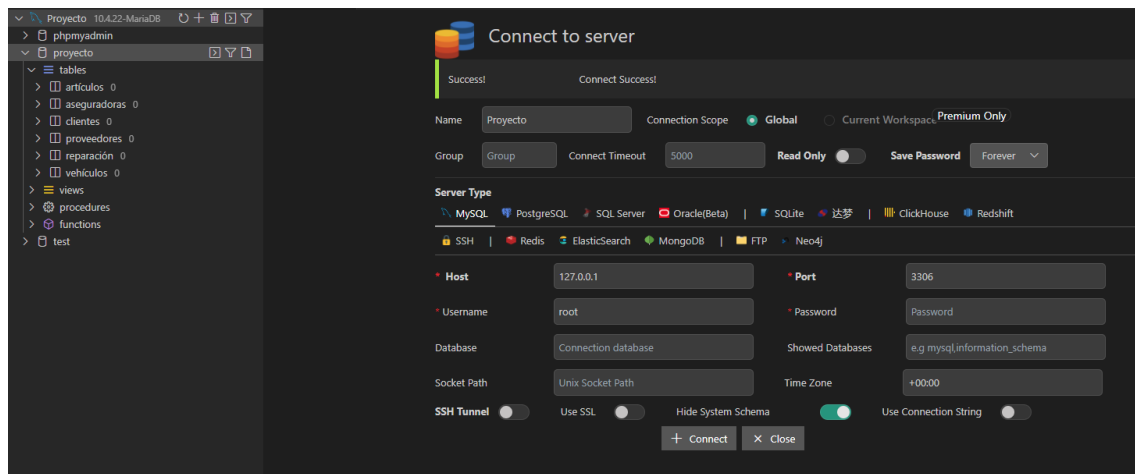
Para acceder a la herramienta basta con, usando el navegador, ingresar la siguiente URL: `servidor/phpmyadmin` (siendo servidor la dirección de este).





Mejoras

Pese a tener ya creada nuestra base de datos, se puede optimizar en gran medida atendiendo a las características de cada tabla, cada campo y cada relación. Para implementar esta serie de medidas decido cambiar de herramienta ya que PHPMyAdmin me resultaba tedioso y poco optimizado para pequeñas tareas. Exploro herramientas tales que Workbench o Netviz pero finalmente me decanto por complementar PHPMyAdmin con la extensión MySQL de Weijan Chen para Visual Studio Code. Esta extensión es de las mejor valoradas para el mantenimiento de bases de datos y me permite acceder a ella rápidamente desde el editor de texto que empleo para la programación del proyecto.



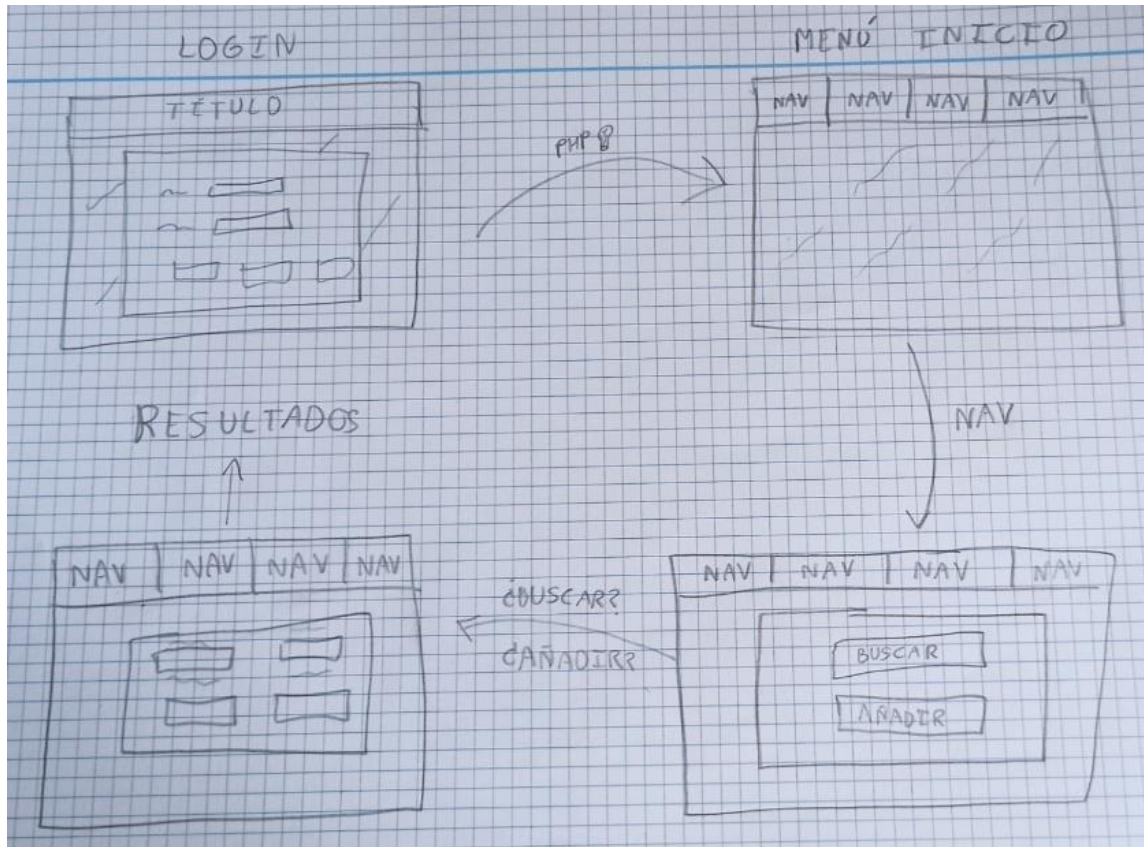
Algunas de las implementaciones que pueden ser añadidas a la base de datos con el fin de mejorar su funcionamiento son:

- Creación de *triggers* que actualicen automáticamente campos dependientes de otros como es el caso del campo “Precio de venta” el cual depende de “Precio” e “Impuesto”.
- Actualización automática del campo “Última reparación” de la tabla “Vehículos”.
- Empleo de técnicas de optimización del servidor para afrontar volúmenes de datos más masivos.

DESARROLLO DEL PROGRAMA

Estructura y diseño

Antes de dar funcionalidad a nuestro programa web para que interactúe con el usuario y la base de datos, debemos de establecer la estructura del mismo sobre la que trabajaremos. En primer lugar, realizo una lluvia de ideas y plasmo la más convincente en un boceto.



Boceto a papel de la página web.

Una vez analizada y aceptada la idea estructural de la página, debe ser llevada a producción. Para ello creo un directorio de trabajo en el servidor de prueba con los respectivos archivos HTML5 y la hoja de estilos CSS3. Como comenté anteriormente, para la edición de texto emplearé Visual Studio Code que me proporciona las herramientas necesarias para centralizar al máximo las tareas a llevar a cabo en el transcurso del proyecto.

Para la realización de la página web debo de tener 3 conceptos claves en mente que son:

- *Responsive Desing*: ya que el código debe de adaptarse a cualquier resolución de pantalla y tamaño del navegador. Para ello emplearé tamaños dinámicos y *media queries*.
- *Flexibilidad*: al ser una versión OpenSource básica, el código debe de ser editable facilmente para poder mejorarlo y adaptarlo a la empresa que aplique el proyecto.
- *Intuitivo*: la primera vez que se acceda al programa, debería de saberse acceder a todas las funciones con facilidad.

TALLERES CILSIN

Nombre de usuario:

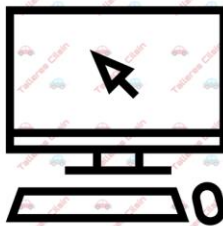
Contraseña:

¿Recordar datos de ingreso? ☐

Contacto de soporte:  

Instantánea de la pantalla de inicio de sesión

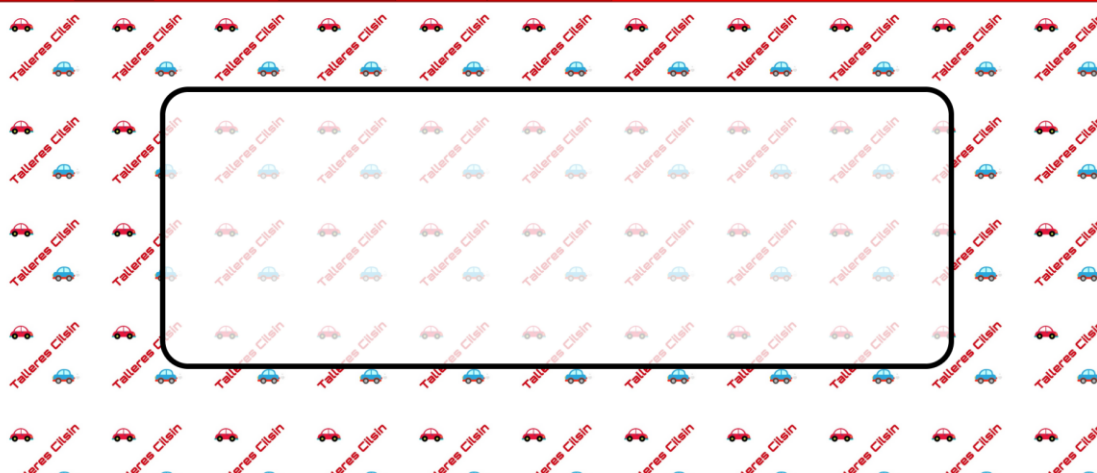
Artículos Clientes Aseguradoras Proveedores Vehículos Presupuestos



Contacto de soporte:  

Instantánea del menú principal

Artículos Clientes Aseguradoras Proveedores Vehículos Presupuestos



Contacto de soporte:  

Instantánea de la pestaña Clientes. Contenido añadido en la fase de Funcionalidad.

Funcionalidad

Ya contando con una estructura sobre la que trabajar, es necesario darle a la página web interacción con el usuario. Esta la aplico en el lado del servidor, empleando PHP. Este lenguaje, desarrollado por el canadiense Rasmus Lerdorf en 1994 y mantenido en la actualidad por The PHP Group, se encuentra en su versión 8 y continúa siendo uno de los lenguajes de programación más empleados del mundo.

Para la conexión con la base de datos emplearé PDO, una extensión de PHP que proporciona abstracción de acceso a datos. Es importante que las sentencias con datos introducidos por el usuario sean preparadas para evitar SQL Injection. Para conectarme a la base de datos he diseñado el siguiente código:

```
<?php
session_start();
/* CONFIGURACIÓN */
define('SERVIDOR', 'direccion_del_server');
define('USUARIO', 'root');
define('CONTRASEÑA', 'p@ssw0rd');
define('BASE_DE_DATOS', 'proyecto');

/* CONEXIÓN */
function conexion() {
    $dbhost=SERVIDOR;
    $dbuser=USUARIO;
    $dbpass=CONTRASEÑA;
    $dbname=BASE_DE_DATOS;
    try {
        $dbConnection = new PDO("mysql:host=$dbhost;dbname=$dbname", $dbuser, $dbpass);
        $dbConnection->exec("set names utf8");
        $dbConnection->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

        return $dbConnection;
    }
    catch (PDOException $e) {
        echo 'Error de conexión: ' . $e->getMessage();
    }
}
conexion();
?>
```

En primer lugar debo implementar el sistema de inicio de sesión. La primera idea era la de crear una nueva tabla en la base de datos que registre los usuarios y el hash de las contraseñas. Cuando un usuario iniciase sesión, PHP recogería los datos de autenticación y los comparará con los datos de registro almacenados devolviendo un código exitoso o no en función de la coincidencia.

No obstante, teniendo en cuenta que a la base de datos solo se conectará un grupo reducido de usuarios los cuales pertenecen a la empresa que decida aplicar el proyecto, me decanto por la idea de crear los usuarios como usuarios de la base de datos para que empleen sus credenciales de forma directa en la conexión a la base de datos a través del programa. Esta característica permitirá controlar los permisos de cada usuario con gran facilidad y es implementable con una pequeña mejora al código de conexión de la base de datos. Este

método permite validar los datos con PHP y no HTML, puntualización fundamental ya que se validan en el lado del servidor.

Con PHPMyAdmin, la creación de usuarios es muy simple. Creamos los usuario alvaro.cilleruelo con todos los privilegios y empleado.raso con solo privilegios de lectura, para comprobar el funcionamiento.

The image displays two screenshots of the PHPMyAdmin 'Agregar cuenta de usuario' (Add user account) form. Both screenshots show the 'Información de la cuenta' (Account information) section with the following details:

- Nombre de usuario:** alvaro.cilleruelo (top) / empleado.raso (bottom)
- Nombre de Host:** Cualquier servidor %
- Contraseña:** [Redacted] Strength: Extremadamente débil
- Debe volver a escribir:** [Redacted]
- Authentication plugin:** Autenticación de MySQL nativo
- Generar contraseña:** Generar

The 'Base de datos para la cuenta de usuario' (Database for the user account) section shows two options:

- ☐ Crear base de datos con el mismo nombre y otorgar todos los privilegios.
- ☐ Otorgar todos los privilegios al nombre que contiene comodín (username_%).

The 'Privilegios globales' (Global privileges) section shows a 'Seleccionar todo' (Select all) button and a note: 'Nota: Los nombres de los privilegios de MySQL están expresados en inglés.' (Note: MySQL privilege names are expressed in English.)

The 'Privilegios globales' section is divided into four categories:

- Datos:** SELECT, INSERT, UPDATE, DELETE, FILE (all checked in the top screenshot, none in the bottom).
- Estructura:** CREATE, ALTER, INDEX, DROP, CREATE TEMPORARY TABLES, SHOW VIEW (all checked in the top screenshot, none in the bottom).
- Administración:** GRANT, SUPER, PROCESS, RELOAD, SHUTDOWN, SHOW DATABASES (all checked in the top screenshot, none in the bottom).
- Límites de recursos:** MAX QUERIES PER HOUR, MAX UPDATES PER HOUR, MAX CONNECTIONS PER HOUR (all set to 0 in both screenshots).

The 'SSL' section shows options for REQUIRE NONE, REQUIRE SSL, REQUIRE X509, and REQUIRE CIPHER, all of which are unchecked in both screenshots.

Para aplicar este método, empleo la variable \$_REQUEST con los datos del formulario de inicio de sesión que diseñamos en HTML dándole a \$dbuser el nombre de usuario y \$dbpass la contraseña. Añado un fragmento de código JavaScript que me permite redirigir al login o al programa en función de si los datos de acceso son correctos o no.

```

<?php
session_start();
/* CONFIGURACIÓN */
define('SERVIDOR', 'localhost');
define('USUARIO', '$_REQUEST["login"]');
define('CONTRASEÑA', '$_REQUEST["password"]');
define('BASE_DE_DATOS', 'proyecto');

/* CONEXIÓN */
function conexion() {
    $dbhost=SERVIDOR;
    $dbuser=USUARIO;
    $dbpass=CONTRASEÑA;
    $dbname=BASE_DE_DATOS;
    try {
        $dbConnection = new PDO("mysql:host=$dbhost;dbname=$dbname", $dbuser, $dbpass);
        $dbConnection->exec("set names utf8");
        $dbConnection->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
        echo "<script language='JavaScript'>
            | location = 'main.html'
        </script>";
        return $dbConnection;
    }
    catch (PDOException $e) {
        echo "<script language='JavaScript'>
            | location = 'index.php?e=error'
        </script>";
    }
}
conexion();
?>

```

Además, cambio el formato al archivo de *login* a PHP y le añado una condición para que indique cuando las credenciales sean incorrectas.

TALLERES CILSIN

Nombre de usuario:

Contraseña:

¿Recordar datos de ingreso? ☐

Las credenciales empleadas son incorrectas.

Contacto de soporte:  

```

<body>
  <header>
    <h1>
      Talleres Cilsin
    </h1>
  </header>
  <main>
    <form class="login" name="login" method="post" action="login.php">
      <div class="login">
        <p>Nombre de usuario:</p>
        <input type="text" name="user"/>
      </div>
      <div class="login">
        <p>Contraseña:</p>
        <input type="password" name="password"/>
      </div>
      <div class="recordar">
        <p>¿Recordar datos de ingreso?</p>
        <input type="checkbox" name="Recordar">
      </div>
      <div class="btn">
        <input type="submit" value="Acceder">
        <input type="reset" value="Reestablecer">
      </div>
    </form>;

    if ($_GET["e"] == 'error') {
      echo '<p class="error">Las credenciales empleadas son incorrectas.</p>';
    }

    echo '</main>
  </body>
</html>

```

Migro el resto de los archivos *.html* a *.php* y añado un mensaje de bienvenida al usuario y un botón de cerrar sesión.

```

<main>
  
';

if (isset($_SESSION["user"])) {
  echo ('<p class="bienvenida">Bienvenido ' . $_SESSION["user"] . '</p>');
}

echo '
</main>
<footer>
  <div>
    <p>Contacto de soporte:</p>
    <a href="tel:+34618629266"></a>
    <a href="mailto:cillegtal11202@gmail.com"></a>
  </div>
  <div>
    if (isset($_SESSION["user"])) {
      echo ('
        
        <p>' . $_SESSION["user"] . '</p>
        <a href="close_session.php"></a>
      ');
    }
  </div>
</footer>
</body>
</html>
';

```



Creo una nueva función que servirá para cerrar la sesión, desconectarse de la base de datos y regresar de nuevo a la pantalla de *login*. Para emplear tanto esta función como la de conexión, ambas trasladadas a *funciones.php*, es necesario añadir al principio de cada archivo la sentencia *include(login.php);*.

```
/* DESCONEXIÓN*/
function desconexion () {
    global $dbConnection;
    $dbConnection = null;
    session_destroy();
    echo "<script language='JavaScript'>
        | location = 'index.php?e=cerrado'
    </script>";
}
```



También debemos de darle funcionalidad al botón de recordar datos de ingreso. Esto se consigue empleando cookies que establecemos en PHP con la variable `$_COOKIE`.

La parte básica del programa es la interacción entre el programa y la base de datos la cual consigo con formularios HTML que envían los datos al servidor que, programado con

PHP, verifica los datos recibidos a través del método POST y los aplica a la base de datos realizando registros, cambios o búsquedas en función de la petición del usuario.

Formulario de búsqueda/ingreso de la tabla artículos.

```
if (isset($_REQUEST["ingresar"])) {
    try {
        $insert = "INSERT INTO artículos VALUES
        ('".$_REQUEST['referencia']."',
        '".$_REQUEST['marca']."',
        '".$_REQUEST['descripcion']."',
        '".$_REQUEST['familia']."',
        '".$_REQUEST['precio_tarifa']."',
        '".$_REQUEST['descuento']."',
        '".$_REQUEST['precio_coste']."',
        '".$_REQUEST['impuesto']."',
        '".$_REQUEST['precio_venta']."',
        '".$_REQUEST['proveedor']."',
        '".$_REQUEST['reparacion']."'
        );";
        $registro = $pdo->prepare($insert);
        $registro->execute();
        echo '<p class="aviso">Se ha ingresado el artículo '".$_REQUEST["referencia"].'</p>';
    }
    catch (PDOException) {
        echo '<p class="error">No ha sido posible ingresar los datos.</p>';
    }
}
```

Código para ingresar un artículo.

```

if (isset($_REQUEST["buscar"])) {
    $consulta = 'SELECT * FROM artículos WHERE
    if[
    ';
    $resultado = $pdo->query($consulta);
    echo '
    <table>
        <tr>
            <th>Referencia</th>
            <th>Descripción</th>
            <th>Marca</th>
            <th>Familia</th>
            <th>Proveedor</th>
            <th>P. Tarifa</th>
            <th>Descuento</th>
            <th>P. Coste</th>
            <th>Impuesto</th>
            <th>P. Venta</th>
            <th>Reparación</th>
        </tr>
        ';
    foreach ($resultado as $valor) {
        echo '
        <tr>
            <td>'.$valor["Referencia"].'</td>
            <td>'.$valor["Descripción"].'</td>
            <td>'.$valor["Marca"].'</td>
            <td>'.$valor["Familia"].'</td>
            <td>'.$valor["Proveedores"].'</td>
            <td>'.$valor["Precio tarifa"].'</td>
            <td>'.$valor["Descuento"].'</td>
            <td>'.$valor["Precio final"].'</td>
            <td>'.$valor["Impuesto"].'</td>
            <td>'.$valor["Precio Venta"].'</td>
            <td>'.$valor["Reparación"].'</td>
        </tr>
        ';
    }
    echo '
    </table>
    ';
}

```

Código para mostrar los registros de artículos.



Instantánea de la pantalla de confirmación de ingreso de registro.

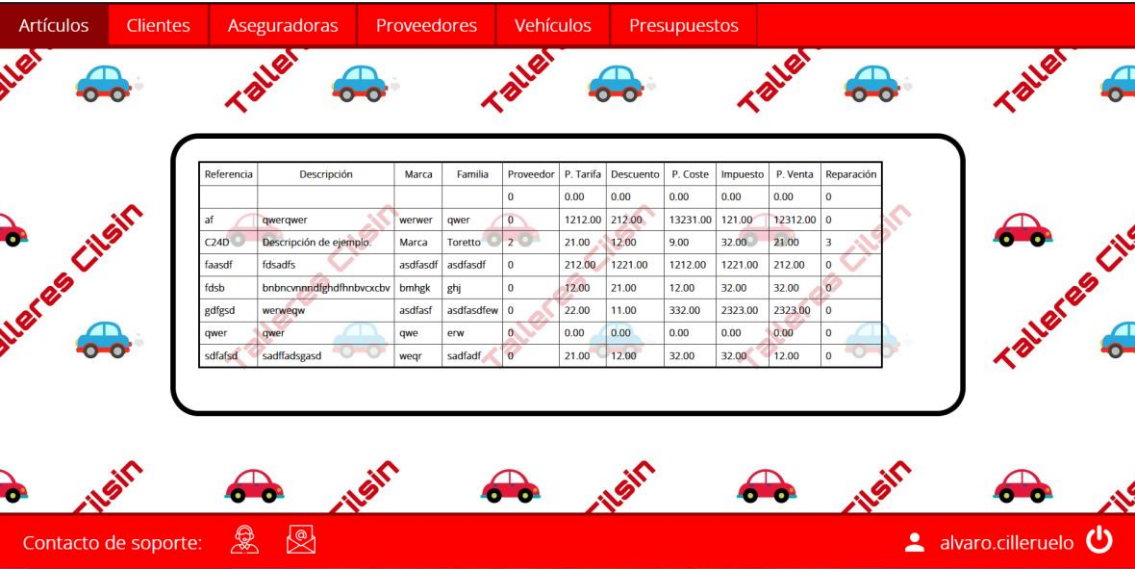


Tabla de resultados a la búsqueda de artículos.

Repetimos el mismo proceso para el resto de las tablas.

Artículos Clientes Aseguradoras Proveedores Vehículos Reparaciones

Taller

DNI: Nombre:

Código Postal: Población:

Teléfono: Teléfono2:

Correo electrónico:

Banco: IBAN:

Otra información: Particular: ☐

Ingresar datos Búsqueda Reestablecer

Contacto de soporte:   alvaro.cilleruelo 

Artículos Clientes Aseguradoras Proveedores Vehículos Reparaciones

Taller

Nombre: NIF:

Dirección: Código Postal:

Población: Teléfono:

Web: Descripción:

Correo electrónico:

Ingresar datos Búsqueda Reestablecer

Contacto de soporte:   alvaro.cilleruelo 

Artículos Clientes Aseguradoras Proveedores Vehículos Reparaciones

Taller

Nombre: NIF:

Dirección: Código Postal:

Población: Teléfono: Teléfono:

Web: Correo electrónico:

Banco: IBAN:

Descripción:

Ingresar datos Búsqueda Reestablecer

Contacto de soporte:   alvaro.cilleruelo 

The screenshot shows the 'Vehículos' form within the ASIR application. The form is centered on a red background with a repeating pattern of the text 'Talleres Cilsin' and car icons. The form itself is a white rounded rectangle with a black border. It contains the following fields: 'Matrícula:' (text input), 'Cliente:' (text input), 'Marca:' (text input), 'Modelo:' (text input), 'Versión:' (text input), 'Kilómetros:' (text input), 'Última ITV:' (text input with a calendar icon), 'Próxima ITV:' (text input with a calendar icon), 'Aseguradora:' (text input), 'Datos seguro:' (text input), and 'Otra información:' (text input). At the bottom of the form are three buttons: 'Ingresar datos', 'Búsqueda', and 'Reestablecer'. Below the form is a red footer bar with the text 'Contacto de soporte:' followed by two icons (a person and an envelope), the username 'alvaro.cilleruelo', and a power icon.

The screenshot shows the 'Reparaciones' form within the ASIR application. The form is centered on a red background with a repeating pattern of the text 'Talleres Cilsin' and car icons. The form itself is a white rounded rectangle with a black border. It contains the following fields: 'Fecha:' (text input with a calendar icon), 'Vehículo:' (text input), and 'Tarifa:' (text input). At the bottom of the form are three buttons: 'Ingresar datos', 'Búsqueda', and 'Reestablecer'. Below the form is a red footer bar with the text 'Contacto de soporte:' followed by two icons (a person and an envelope), the username 'alvaro.cilleruelo', and a power icon.

Una vez realizados los menús, deben de perfeccionarse las funcionalidades de administración permitiendo editar y borrar registros desde el programa; validarse los datos ingresados desde el lado del servidor con estructuras condicionales; y añadir filtros de ingreso y búsqueda para facilitar estas tareas.

MEJORAS

Llegando a este punto, ya cuento con el programa básico que buscaba junto a su base de datos pero es necesario implementar diversos requerimientos de seguridad y funcionalidades de interés que ofrezcan un distintivo al proyecto para hacerlo atractivo al usuario.

Securización mediante certificado SSL/TLS

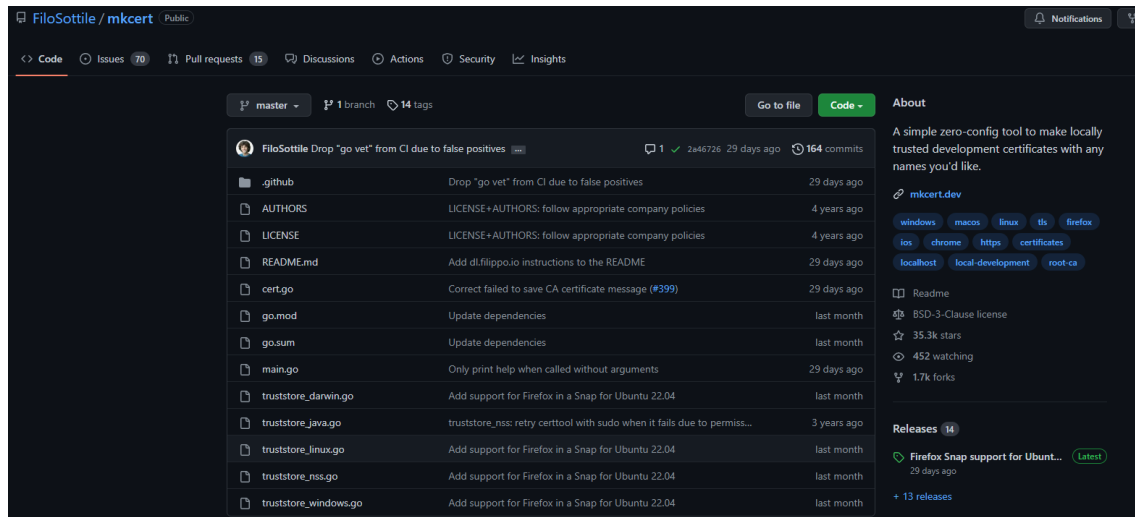
Este apartado, aunque quede en la fase de mejoras, es fundamental ya que permite emplear el protocolo HTTPS en lugar de HTTP para realizar la conexión web al servidor. Gracias a esto, la información compartida entre el cliente y el servidor queda cifrada bajo el certificado protegiéndola ante ataques potenciales como el *sniffing* o el *spoofing*. El empleo de este protocolo cobra vital importancia al tratarse de una aplicación que intercambia constantemente datos corporativos confidenciales.

Para realizar esta securización debo generar un certificado firmado por una entidad certificadora fiable como es el caso de la Casa Nacional de la Moneda y Timbre. Al tratarse de una implantación de prueba, genero el certificado personalmente y lo instalo en el servidor. Una herramienta muy útil a la que considero hacer mención es *mkcert*, la cual se instala desde su repositorio oficial de GitHub y ofrece certificados locales con ventajas como el crear un certificado para *localhost* que los navegadores encuentran seguro (aunque esto se puede conseguir localmente añadiendo la entidad certificadora como segura en tu equipo).

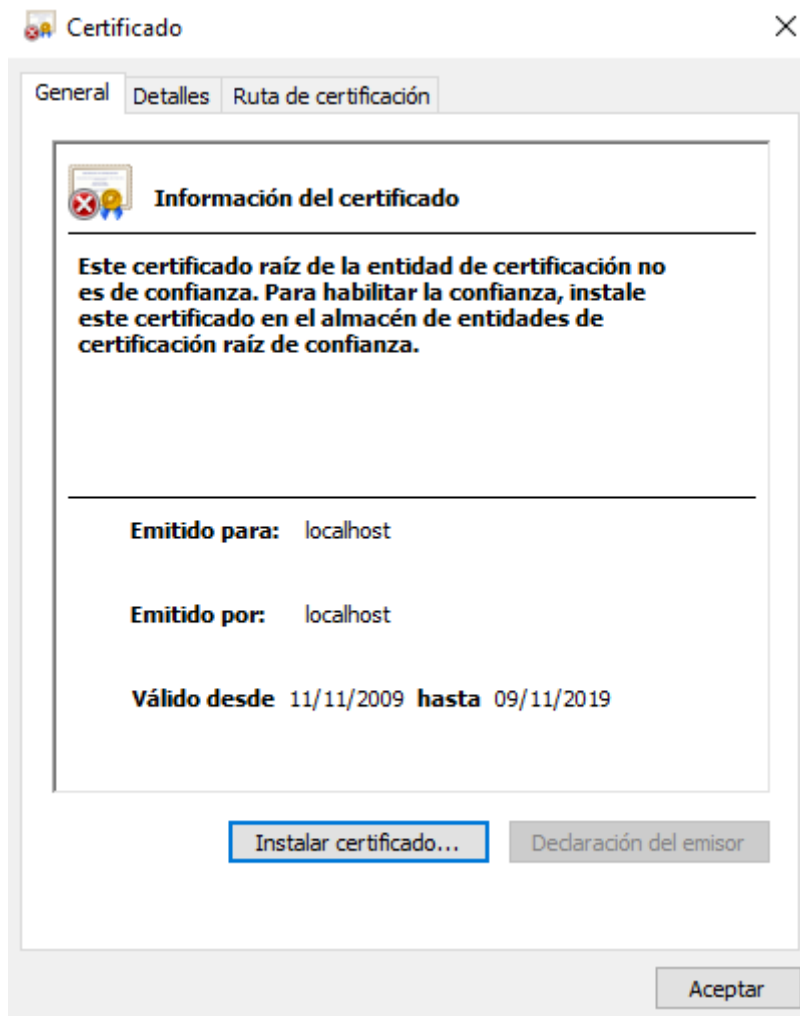


The screenshot shows the website of the Real Casa de la Moneda y Timbre. The header includes the logo and navigation links: CERES, SEDE ELECTRÓNICA, MUSEO CASA DE LA MONEDA, SIAEN, ESCUELA DE GRABADO, and TIENDA VIRTUAL. The main navigation bar lists: Productos y Soluciones, Servicios, Innovación, Coleccionista, Institución, and Transparencia. The breadcrumb trail is: Inicio > Servicios > Certificación Digital. On the left, a sidebar menu lists: Digitalización, Asesoría y Consultoría Integral, Proyectos de Identificación, Certificación Digital (highlighted), Laboratorio, Preimpresión, Medallas a medida, and Alquiler de Salas de Eventos. The main content area is titled 'Certificación Digital' and contains the following text: 'La FNMT-RCM, como Proveedor de Servicios de Certificación a través de CERES, ha implementado una serie de aplicaciones que permiten a la Administración, a los ciudadanos y a las empresas españolas realizar sus trámites a través de Internet de forma totalmente segura. Las nuevas soluciones de certificación y autenticación de identidad digital que ofrece la FNMT-RCM proporcionan validez y seguridad a las transacciones electrónicas.' Below this, there is a section titled 'Certificación de firma electrónica' with a description: 'El sistema de certificación de firma electrónica establecido por la FNMT-RCM es un intermediario transparente al ciudadano, de fácil uso, que ofrece alta disponibilidad y gran capacidad de acceso concurrente para los usuarios de la red. Este sistema ya está operativo con diversas aplicaciones en funcionamiento y numerosos organismos en fase de incorporación al sistema. Los certificados emitidos por la FNMT-RCM son de uso general y por lo tanto universales, es decir, cada ciudadano puede comunicarse con las diferentes administraciones con un único certificado.' At the bottom, there are two links: 'Cómo obtener su Certificado Digital FNMT de Persona Física' and 'Obtenga el Certificado de Usuario'.

Página para la petición de certificados digitales avalados por la Casa Nacional de Moneda y Timbre. <https://www.fnmt.es/ceres>



Repositorio oficial de mkcert. <https://github.com/FiloSottile/mkcert>



Certificado generado manualmente detectado como no confiable debido a que la entidad certificadora no se encuentra en el almacén de certificados raíz y la fecha de validez ha expirado.

Esta instalación se realiza situando el certificado en un directorio del servidor e indicando la ruta a este en el archivo de configuración SSL de Apache. Este fichero varía según el servidor, el sistema operativo e incluso las versiones pero algunos ejemplos serían: /etc/httpd/conf.d/ssl.conf en CentOS, /etc/apache2/sites-available/ssl.conf en la pila

LAMP del Ubuntu Server o C:\xampp\apache\conf\original\extra\httpd-ssl.conf en el servidor XAMPP instalado en Windows 10 (son ejemplos, todo esto varía en función de las versiones).

```
# Server Certificate:
# Point SSLCertificateFile at a PEM encoded certificate. If
# the certificate is encrypted, then you will be prompted for a
# pass phrase. Note that a kill -HUP will prompt again. A new
# certificate can be generated using the genkey(1) command.
SSLCertificateFile /etc/pki/tls/certs/certificate.crt ←
#
# Server Private Key:
# If the key is not combined with the certificate, use this
# directive to point at the key file. Keep in mind that if
# you've both a RSA and a DSA private key you can configure
# both in parallel (to also allow the use of DSA ciphers, etc.)
SSLCertificateKeyFile /etc/pki/tls/private/certificate.key ←
```

Rutas al certificado y su clave en el archivo de configuración SSL de Apache en CentOS.

```
# SSL Engine Switch:
# Enable/Disable SSL for this virtual host.
SSLEngine on

# A self-signed (snakeoil) certificate can be created by installing
# the ssl-cert package. See
# /usr/share/doc/apache2/README.Debian.gz for more info.
# If both key and certificate are stored in the same file, only the
# SSLCertificateFile directive is needed.
SSLCertificateFile /etc/ssl/certs/ssl-cert-snakeoil.pem }
SSLCertificateKeyFile /etc/ssl/private/ssl-cert-snakeoil.key }
```

Rutas al certificado y su clave en el archivo de configuración SSL de Apache en Ubuntu Server.

httpd-ssl.conf: Bloc de notas

Archivo Edición Formato Ver Ayuda

```
# require an ECC certificate which can also be configured in
# parallel.
SSLCertificateFile "${SRVROOT}/conf/server.crt" ←
#SSLCertificateFile "${SRVROOT}/conf/server-dsa.crt"
#SSLCertificateFile "${SRVROOT}/conf/server-ecc.crt"

# Server Private Key:
# If the key is not combined with the certificate, use this
# directive to point at the key file. Keep in mind that if
# you've both a RSA and a DSA private key you can configure
# both in parallel (to also allow the use of DSA ciphers, etc.)
# ECC keys, when in use, can also be configured in parallel
SSLCertificateKeyFile "${SRVROOT}/conf/server.key" ←
#SSLCertificateKeyFile "${SRVROOT}/conf/server-dsa.key"
#SSLCertificateKeyFile "${SRVROOT}/conf/server-ecc.key"
```

Rutas al certificado y su clave en el archivo de configuración SSL de XAMPP.

Nombre	Fecha de modificación	Tipo	Tamaño
server.crt	30/03/2013 13:29	Certificado de seg...	1 KB

Certificado no fiable instalado por defecto en el servidor XAMPP.

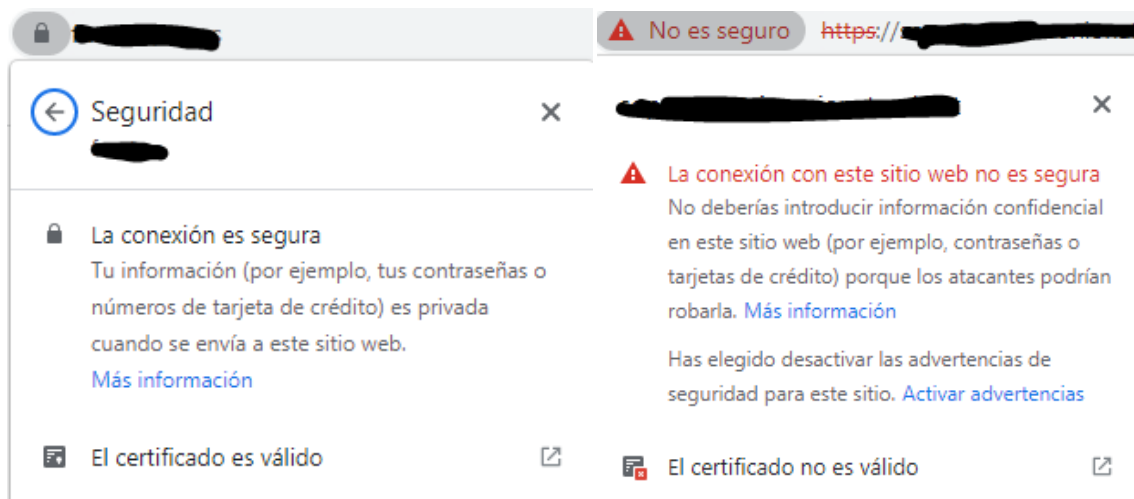
Una vez instalado el certificado comprobamos que cambiando <http://> en la URI por <https://>, el navegador indica que la conexión es segura. No obstante, si introducimos solamente la URL del servidor empleará por defecto el protocolo HTTP. Hay diversos métodos para solucionar este problema pero me decanto por redireccionar las conexiones del puerto 80 (HTTP) al 443 (HTTPS). Esta solución es óptima para el entorno actual. No obstante, podría ser necesario reestudiarla para un programa más extenso pudiendo suponer problemas de optimización debido a las redirecciones. Para implementar este cambio, ajustamos el fichero de configuración del servidor Apache añadiendo las siguientes líneas en las conexiones respectivas al puerto 80.

RewriteEngine On

RewriteCond %{HTTPS} off

RewriteRule ^(.*)\$ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]

(Es un ejemplo para un caso particular, recomiendo investigar la solución óptima en cada caso)



Ejemplo de los avisos realizados por Google al realizar una conexión HTTPS en caso de certificado válido o no.

Protección de datos

En semejanza con el anterior apartado, esta mejora se vuelve necesaria por motivos legales. Para crear una página web que opera con información personal debemos de seguir los requisitos del Reglamento General de Protección de Datos (RGPD), la Ley Órgánica 3/2018, de 5 de diciembre, de Protección de Datos de Carácter Personal y garantía de los derechos personales (LOPD-GDD) y la Ley 34/2002, de 11 de julio, de Servicios de la Sociedad de la Información y Comercio Electrónico (LSSICE).

De esté ámbito se debe encargar la empresa que aplique el proyecto pero comentaré, tras una pequeña investigación sobre el tema, una serie de conceptos a tener en cuenta a la hora de realizar estos trámites.

Es de obligado cumplimiento para cualquier página web incluir un aviso legal que recopile información acerca del titular de la web como es la razón social, el NIF o CIF,

los datos del domicilio fiscal o social, los datos de contactos, los datos de inscripción en el Registro Mercantil (si es el caso) o las autorizaciones convenientes.

En caso de contar con un formulario de contacto, se debe indicar la finalidad de los datos recopilados a través de este, su permanencia, su seguridad, etc. y registrar el fichero de almacenamiento de estos en la Agencia Española de Protección de Datos para que verifique que todo es correcto.

Si se emplean cookies es necesario mostrar un aviso de que estas pueden ser rechazadas pese a que esto pueda considerar una reducción de funcionalidad de la web.

En el caso del proyecto, pese a operar con datos personales, los requerimientos de este tipo son leves ya que no recopila los datos especialmente críticos a través de la página web aunque es posible que se requiera recopilar cierta información de *tracking* o que el usuario decida implementar una herramienta dedicada a los clientes. En cualquier caso, de cara a facilitar todo este proceso legal, la Agencia Española de Protección de Datos ofrece en su página web una herramienta en la que, mediante un formulario sobre las características de la página web y la empresa, te ofrece una plantilla y una explicación de cada documentación básica a tener en orden para evitar problemas legales aunque es simplemente complementaria. La herramienta descrita previamente es Facilita RGPD pero, a mayores, la AEPD cuenta con otras herramientas a tener en cuenta.

Herramientas

 Facilita RGPD ¿Eres una PyME? Prueba este asistente, te dirá qué tienes que hacer con tus tratamientos de datos personales de escaso nivel de riesgo Entrar →	 Canal del DPD El canal de la persona Delegada de Protección de Datos tiene como finalidad atender las consultas planteadas ante la AEPD por las personas Delegados de Protección de Datos, tanto del sector público como del privado, al desempeñar las funciones encomendadas en el artículo 39 del Reglamento General de Entrar →
 Gestiona EIPD Asistente para el análisis de riesgos y evaluaciones de impacto en protección de datos. Entrar →	 Facilita EMPRENDE Herramienta para ayudar a las personas emprendedoras y startups tecnológicas a cumplir con la normativa de protección de datos Entrar →
 Comunica-Brecha RGPD Con esta herramienta una persona responsable de tratamiento puede obtener una valoración que le asista en la toma de decisiones sobre la obligación de comunicar a las personas afectadas por una brecha de seguridad de los datos personales. Entrar →	 Evalúa-Riesgo RGPD Herramienta para el análisis de necesidad de una Evaluación de Impacto en Protección de Datos Entrar →

Herramientas ofrecidas por la AEPD para facilitar el cumplimiento de la legislación de protección de datos.
<https://www.aepd.es/es/guias-y-herramientas/herramientas>

El programa ha terminado, cuando pulse el botón de FINALIZAR se generaran diversos documentos en formato editable.

RECUERDE, aunque se le ofrecen los documentos mínimos indispensables para estar en disposición de cumplir con el Reglamento de Protección de Datos, usted también debe realizar las siguientes acciones:

1. Incluir las cláusulas informativas en los formularios de solicitud de información, bien si utiliza formularios en papel o a través de su página web.
2. Implantar las medidas técnicas y organizativas que se le indican en el documento correspondiente.
3. Revisar los contratos que dispone actualmente e incluir las cláusulas contractuales y firmarlas en la última hoja.
4. Elaborar aquellos contratos que todavía no tiene e igualmente incluir las cláusulas contractuales y firmarlas en la última hoja.
5. Custodiar y mantener actualizados todos los documentos.
6. No olvide que no debe enviar nada a la Agencia Española de Protección de Datos, tan solo debe entregárselos si se los solicita.
7. Recuerde que la Agencia Española de Protección de Datos no almacena la información que usted haya introducido en esta herramienta.

Instrucciones de uso del documento generado por Facilita RGPD mostradas al finalizar el formulario.

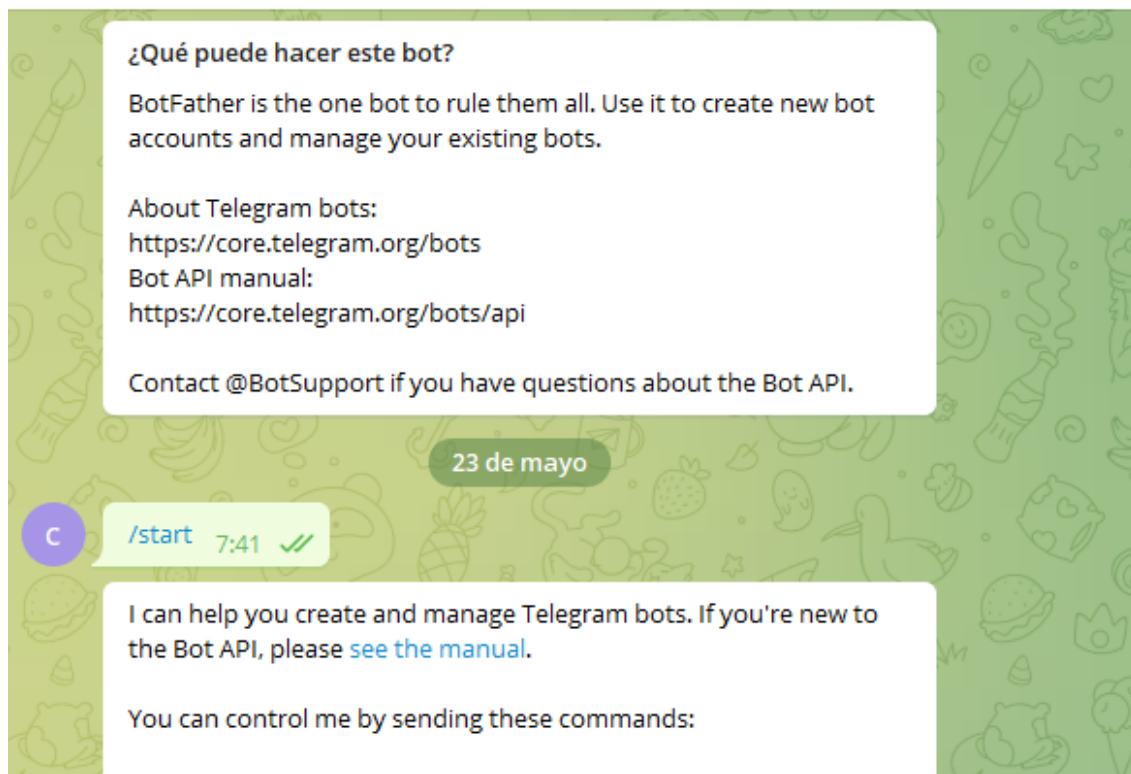
Soporte vía Telegram

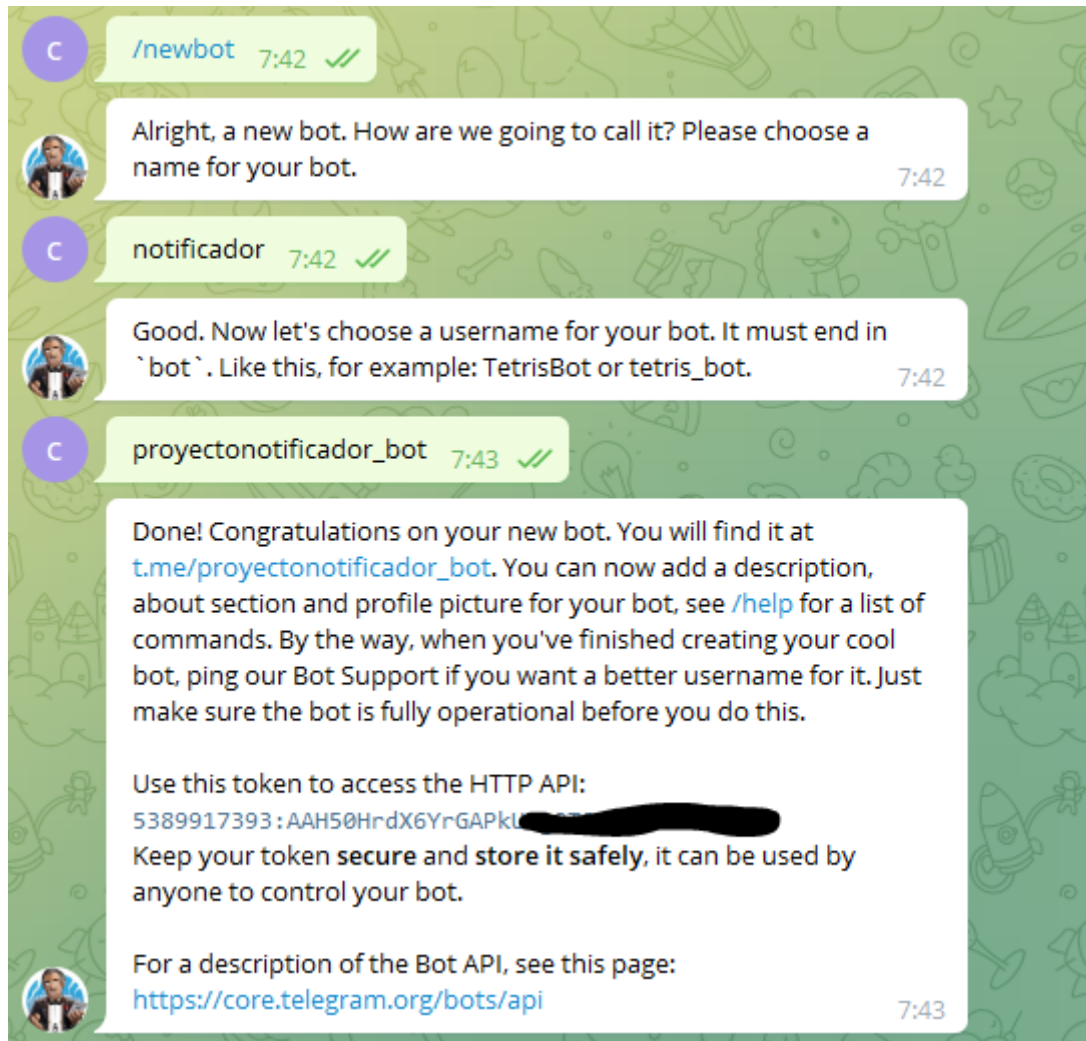
Además de los enlaces de contacto al soporte por teléfono y correo electrónico, decido implementar un formulario de contacto. Este formulario de contacto por lo general se envía en el *backend* por correo electrónico a los administradores pero decido indagar más en el tema y opto por una solución a través de mensajería instantánea.

Para esta implantación opto por la aplicación Telegram la cual felicita el proceso gracias a sus canales de difusión y a la posibilidad de crear *chatbots* personalizados que automaticen tareas. Para crear el *bot* empleo FatherBot, el cual es a su vez un *chatbot* que permite crear el tuyo propio personalizándolo al máximo sin necesidad de *conocimientos* de programación.

BotFather

bot





Creación del chatbot a través de FatherBot (vía Telegram).

Una vez creado el *chatbot* al que llamo “notificador”, debe de guardarse el *token* de acceso a la interfaz de programación de aplicaciones HTTP o API HTTP para emplearlo posteriormente en el código PHP (recomiendo almacenarlo como una variable a la que llamar posteriormente). Además, para que el notificador haga llegar las incidencias de la página a los administradores debe crearse un canal de difusión público con aquellos que vayan a recibir estos mensajes. Posteriormente, se añade al notificador al grupo otorgándole permisos de administración. Debemos de guardar el nombre del canal al igual que el *token*, lo haremos con el formato *@nombre*. También es posible que el *chatbot* mande el mensaje a una sola persona por chat privado, en este caso necesitaremos la ID del usuario.

Finalmente, debe programarse la aplicación para que envíe las incidencias al notificador. Para ello empleo la función *curl* de PHP aunque al ser una utilidad en desarrollo existen gran cantidad de métodos con resultados similares.

```

if (isset($_REQUEST["asunto"]) | isset($_REQUEST["mensaje"])) {
    $token = 'Introducir el token del FatherBot';

    $datos = [
        'chat_id' => '@ del canal de difusión o ID del usuario de Telegram',
        'text' => 'Ha llegado una incidencia con el asunto "'.$_REQUEST["asunto"].'" debido al siguiente motivo: "'.$_REQUEST["mensaje"]."',
        'parse_mode' => 'MarkdownV2' #formato del mensaje
    ];
    $ch = curl_init();

    curl_setopt($ch, CURLOPT_URL, "https://api.telegram.org/bot" . $token . "/sendMessage");
    curl_setopt($ch, CURLOPT_HEADER, false);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, 1);
    curl_setopt($ch, CURLOPT_POST, true);
    curl_setopt($ch, CURLOPT_POSTFIELDS, $datos);
    curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);

    $verificador = json_decode(curl_exec($ch), true);

    curl_close($ch);
    if ($verificador['ok'] == 1) {
        echo "<p class='aviso'>Mensaje enviado.</p>";
    } else {
        echo "<p class='error'>Mensaje no enviado.</p>";
    }
}

```

TALLERES CILSIN

CENTRO DE SOPORTE POR TELEGRAM

Asunto

Motivo de la incidencia

Contacto de soporte:
Inicio de sesión

Otras mejoras interesantes no aplicadas

Además de las mejoras llevadas a producción anteriormente, hay una serie de mejoras que no han entrado en la versión inicial del proyecto pero sería de interés implementarlas como valor añadido al programa:

- Sistema de doble autenticación o *2FA*, el cual permite dotar de mayor seguridad al sistema de autenticación no limitándose, como es tradicional, a una clave memorizada, sino añadiendo un método complementario basado en un código generado en otro dispositivo al que solo el usuario tiene acceso. Este método está teniendo un auge importante pese a que el concepto lleva empleándose mucho tiempo sustituyendo el código digital por una “llave” física.
- Generación automática de facturas, albaranes y otros documentos de administración a partir de los registros almacenados en la base de datos.
- Posibilidad de sustituir la página web por un programa instalado de forma local en los equipos dependiendo de la topología de red y el funcionamiento de la empresa cliente, acción que ha sido simplificada considerablemente en los últimos años gracias a métodos y herramientas como Progressive Web Apps o PWAs.

- Diseño de interfaz oscura. Esta mejora puede parecer de carácter muy secundario pero está demostrado que gran cantidad de usuarios pueden llegar a declinar una web por la falta de opciones para ajustar la tonalidad en función de los gustos propios o la luminosidad ambiental.
- Centralizar los archivos del programa en uno evitando así transiciones y tiempos de carga.
- Permitir la importación y exportación de datos para facilitar la migración de base de datos y programa. Este punto es importante ya que es una de las carencias que presentan los programas de este estilo más empleado debido a que generalmente son patrocinados por marcas o proveedores que buscan la exclusividad.
- Incluir una herramienta, archivo de configuración y/o guía de usuario que permita, a aquellas empresas que decidan aplicar el proyecto, la utilidad de modificar aspectos básicos como la paleta de colores, el nombre corporativo o el fondo de la página web de forma muy sencilla sin necesidad de conocer el código del programa.
- Implementar funcionalidad al botón de “¿Recordar credenciales de inicio de sesión?” ya que se implementó en el diseño de la web pero no se le aplicó la programación pertinente debido a la priorización de tareas.

FUENTES EMPLEADAS

<https://es.stackoverflow.com>

www.freepik.es

https://www.youtube.com/watch?v=5g_ydq6MJac&t=89s

<https://www.phpmyadmin.net/>

<https://ayudaleyprotecciondatos.es/tiendas-online/>

<https://www.aepd.es/es/informes-y-resoluciones/normativa-y-circulares>

<https://eur-lex.europa.eu/collection/eu-law/legislation/recent.html?locale=es>

<https://www.semrush.com/blog/redirect-http-to-https/>

<http://soporte.patrimonionatural.net/wiki/>

<https://es.wikipedia.org/wiki/PHP>

<https://blog.interdominios.com/7-tendencias-de-desarrollo-web-que-se-esperan-en-2021/>

<https://abdc.es/blog/cuales-son-los-requisitos-legales-que-debe-cumplir-una-web/>

<https://ticnegocios.camaravalencia.com/servicios/tendencias/que-minimos-legales-debe-cumplir-mi-pagina-web/#1473090422477-ec1da13f-4000>

<https://lawebdetuvida.com/requisitos-legales-cumplir-lopd-ssi/>

<https://www.juntadeandalucia.es/servicios/madeja/contenido/recurso/258>

https://programacion.net/articulo/sistema_de_login_php_con_pdo_1467

<https://www.php.net/manual/es/index.php>

<https://www.mclibre.org/consultar/php/index.html>

<https://www.jasoft.org/Blog/post/como-generar-certificados-https-para-desarrollo-local-que-no-produzcan-errores>

<https://www.flaticon.es>

<https://bitbucket.org/edrperez/various/src/master/chatbot-telegram-php/>

Mención especial a Talleres Cilleruelo y a los docentes del IES Julián Marías en el Grado Superior de Administración de Sistemas Informáticos en 1ºB 2020/21 y 2ºA 2021/22 por su aportación al proyecto.